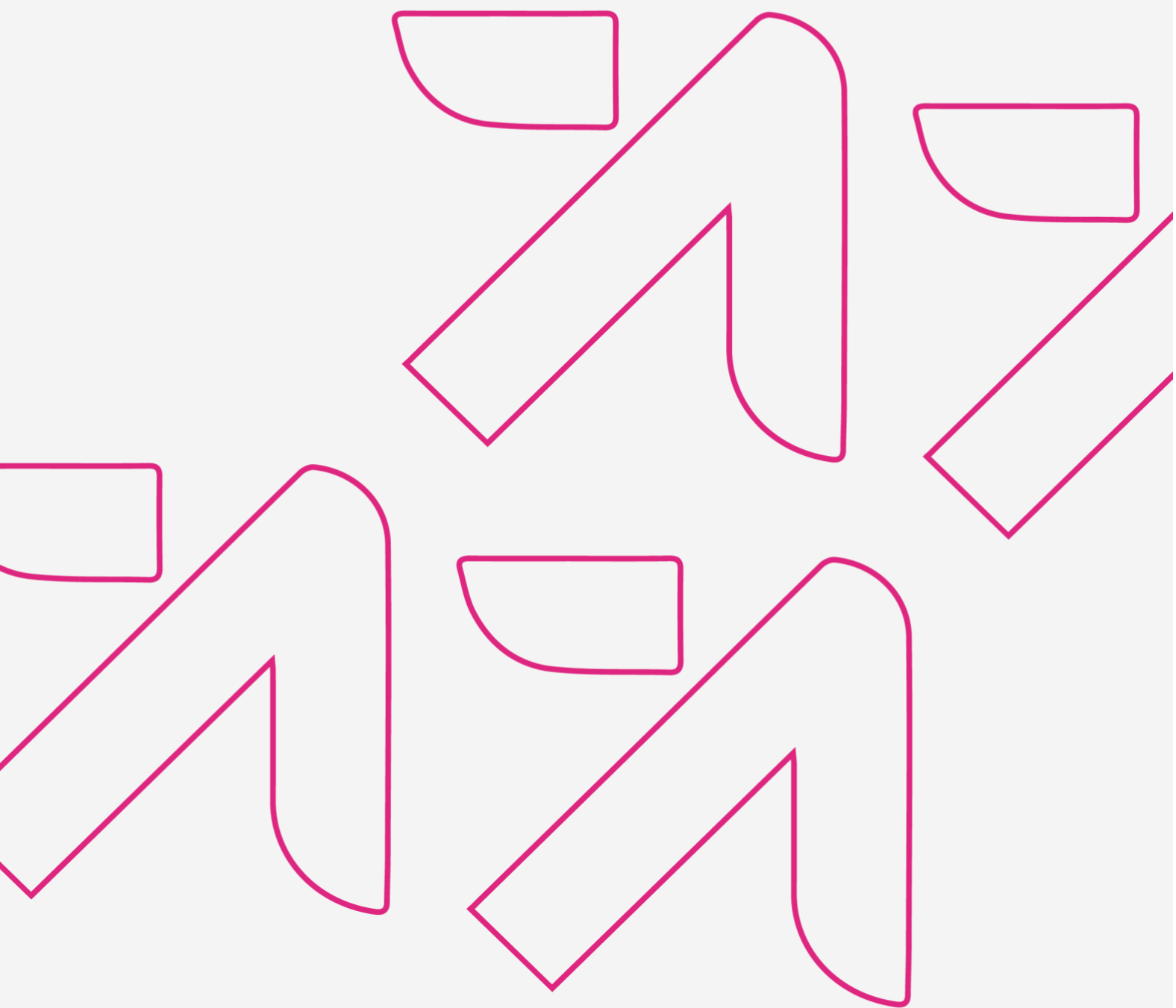




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 7. Investigación y gestión de incidentes de ciberseguridad

Encaje en el curso 2026/2027: tema 7 del temario oficial, dentro del RA4 (implementar medidas respondiendo a los incidentes detectados).

1. Gestionar un incidente

Gestionar un incidente es coordinar personas, decisiones y tiempo bajo presión. La parte técnica es solo una de las piezas: también hay que decidir, comunicar y documentar.

Tres objetivos, por este orden: limitar el daño, recuperar la actividad y entender qué ha pasado para que no se repita.

1.1. El equipo de respuesta

Rol	Función
Responsable del incidente	Coordina y decide; es la única voz de mando
Analistas técnicos	Investigan, contienen y recuperan
Comunicación	Mensajes internos y externos
Legal y protección de datos	Obligaciones de notificación, contratos, denuncias
Dirección	Decisiones de negocio: parar un servicio, asumir un coste
Proveedores	Soporte de sistemas, respuesta externa, aseguradora

En una empresa pequeña varios roles recaen en la misma persona, pero conviene saber cuál se está ejerciendo en cada momento.

2. Metodologías

2.1. Fases

Los dos modelos más usados dicen lo mismo con distinta agrupación:

NIST SP 800-61	SANS (PICERL)
Preparación	Preparación
Detección y análisis	Identificación
Contención, erradicación y recuperación	Contención; erradicación; recuperación
Actividad posterior al incidente	Lecciones aprendidas

La revisión más reciente de la guía de NIST (2025) reorganiza estas tareas según las funciones de su marco de ciberseguridad (gobernar, identificar, proteger, detectar, responder y recuperar), pero el trabajo es el mismo.

2.2. Registro desde el minuto uno

Se abre un registro del incidente en cuanto se confirma, y se anota todo con hora: qué se observa, qué se decide, quién lo hace. Sirve para coordinar durante el incidente, para el informe posterior y para las notificaciones legales.

3. La investigación

3.1. Las preguntas

- **¿Qué** ha pasado y qué tipo de incidente es?
- **¿Cuándo** empezó? Casi siempre antes de lo que parece.
- **¿Por dónde** entraron? El vector de entrada.
- **¿Hasta dónde** han llegado? Sistemas, cuentas y datos afectados: el alcance.
- **¿Siguen dentro?**
- **¿Qué** se han llevado o modificado?

3.2. Triage

Primera valoración rápida: confirmar que es un incidente real, clasificarlo según la taxonomía (tema 3), estimar peligrosidad e impacto y asignarle prioridad.

3.3. Línea temporal

Es la herramienta central de la investigación: ordenar por hora los eventos de todas las fuentes. Con un extracto como este ya se puede contar una historia:

```
02:13:07 sshd    Failed password for admin from 203.0.113.50
02:13:09 sshd    Failed password for admin from 203.0.113.50
... (412 intentos más)
02:31:44 sshd    Accepted password for admin from 203.0.113.50
02:33:02 sudo    admin : COMMAND=/usr/sbin/useradd -m -G sudo soporte2
02:34:18 sshd    Accepted password for soporte2 from 203.0.113.50
02:40:51 cron     (soporte2) REPLACE (soporte2)
```

Fuerza bruta con éxito a las 02:31, creación de una cuenta con privilegios dos minutos después y una tarea programada para mantener el acceso. Tres consejos: unificar todas las horas a UTC, anotar la fuente de cada línea y distinguir entre hechos e hipótesis.

3.4. Causa raíz

No basta con «entraron por SSH». Preguntar «¿por qué?» varias veces seguidas lleva a la causa que de verdad hay que corregir: ¿por qué funcionó la fuerza bruta? Porque la contraseña era débil. ¿Por qué se admitían contraseñas? Porque no se había aplicado la guía de bastionado. ¿Por qué? Porque el servidor se montó con prisas y nunca pasó revisión.

3.5. Modelos para ordenar lo que se sabe

- **Cyber Kill Chain:** en qué fase estaba el ataque cuando se detectó.

- **MITRE ATT&CK:** qué técnicas concretas se han usado.
- **Modelo del diamante:** relaciona cuatro vértices (adversario, capacidad, infraestructura y víctima); conocer uno ayuda a descubrir los demás.

4. Intercambio de información

4.1. Con proveedores

- Proveedor de Internet, alojamiento o nube: registros, bloqueos, conservación de datos.
- Fabricantes de seguridad: análisis de muestras, firmas.
- Empresa de respuesta a incidentes y aseguradora, si hay ciberpóliza: muchas exigen avisar antes de actuar.
- Los contratos deben prever de antemano plazos y contactos para estos casos.

4.2. Con organismos competentes

- **INCIBE-CERT** o **CCN-CERT**, según el tipo de entidad: apoyo técnico, indicadores y coordinación.
- **Fuerzas y cuerpos de seguridad** (Policía Nacional, Guardia Civil, policías autonómicas) cuando hay delito: se presenta denuncia aportando las evidencias.
- **AEPD** si hay datos personales afectados.

Los plazos y la forma de notificar se ven en el tema 10.

4.3. Qué compartir y cómo

Indicadores de compromiso, técnicas observadas y medidas que han funcionado, marcados con el nivel TLP adecuado. Compartir ayuda a otros y suele volver en forma de información útil; existen plataformas específicas para ello, como MISP.

5. Contención

Contener es impedir que el incidente crezca mientras se investiga. Es una decisión de equilibrio: si se actúa demasiado pronto y a medias, el atacante se da cuenta y cambia de táctica; si se tarda, el daño aumenta.

5.1. Tipos de medidas

- **A corto plazo:** frenar ya. Aislar equipos, bloquear una IP o un dominio, deshabilitar una cuenta.
- **A largo plazo:** mantener el servicio de forma segura mientras se prepara la solución definitiva. Parches temporales, reglas adicionales, sistemas alternativos.

5.2. Antes de contener

- ¿Se han recogido las evidencias volátiles? (tema 6)
- ¿Se conoce el alcance? Aislar un equipo cuando hay cinco comprometidos solo avisa al atacante.
- ¿Qué impacto tiene la medida en el negocio y quién la autoriza?

5.3. Estrategias según el tipo de incidente

Incidente	Contención habitual
Malware en un equipo	Aislarlo de la red sin apagarlo; bloquear el hash y los dominios asociados
Ransomware	Aislar segmentos enteros; desconectar las copias de seguridad; deshabilitar cuentas comprometidas
Cuenta comprometida	Cambiar contraseña, cerrar todas las sesiones y revocar tokens; revisar reglas de reenvío y dispositivos MFA añadidos
Phishing recibido por muchos	Retirar el correo de los buzones; bloquear remitente y URL; identificar quién hizo clic
Web comprometida	Página de mantenimiento, conservar copia del sitio alterado, revisar accesos y credenciales
DDoS	Activar el servicio de mitigación del proveedor; filtrar en origen
Fuga de datos por un empleado	Retirar accesos, preservar evidencias; intervienen recursos humanos y asesoría jurídica
Equipo perdido o robado	Borrado remoto, revocar credenciales y certificados; valorar si hay brecha de datos

6. Después de contener

La contención no cierra el incidente. Siguen la erradicación (eliminar la causa y todo rastro del atacante), la recuperación (volver a la normalidad de forma controlada) y la verificación. Se desarrollan en el tema 8.

7. Criterios de cierre

Un incidente se cierra cuando se cumple todo lo siguiente:

- La causa raíz está identificada y corregida.
- No hay indicios de actividad del atacante tras un periodo de vigilancia reforzada.
- Los servicios están restablecidos y verificados.
- Las notificaciones obligatorias están hechas.

- El registro del incidente está completo y hay fecha para la reunión de lecciones aprendidas.

Para ampliar

- NIST SP 800-61: guía de gestión de incidentes.
- SANS: Incident Handler's Handbook.
- Guía CCN-STIC 817: gestión de ciberincidentes en el ENS.
- ISO/IEC 27035: gestión de incidentes de seguridad de la información.
- Proyecto MISP: plataforma abierta de intercambio de información sobre amenazas.